Análise de arquivo suspeito

Share

codigo.sh
26 lines

SH

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Revisando a formatação e as seções da resposta final

Já adianto: é **malware**, mais precisamente um *dropper* de criptomineração (*cryptojacking*), pelo que o script indica. Segue a análise.

Passo a passo

1. **Origem do download.** `URL=http://23.252.123.134:18095/fleet_lin.tgz` aponta para um IP "cru", em porta alta fora do padrão, via HTTP puro e sem verificação de hash ou assinatura. Software legítimo costuma vir de um domínio identificável, por HTTPS e com checagem de integridade. O nome `fleet_lin` sugere uma "frota" de máquinas Linux.
2. **Pasta oculta.** `D=/tmp/.qc$$` cria em `/tmp` um diretório começado por ponto (invisível em um `ls` comum), com o PID no nome. Se a criação falhar, o script usa o próprio `/tmp`. Nada no script exige privilégios de root.
3. **Download "a qualquer custo".** Tenta `curl`, depois `wget`, depois `python3` e por fim `python` 2 (`urllib2`), sempre em modo silencioso e com erros descartados. Essa cascata faz o script funcionar até em contêineres e servidores minimalistas, o que é típico de dropper. Se tudo falhar, imprime `NODL <hostname>` e sai.
4. **Extração.** `tar xzf f.tgz` descompacta o pacote na pasta oculta (em caso de erro, imprime `NOTAR <hostname>`). O conteúdo do pacote não está no script, e esse é o ponto cego da análise.
5. **Marcador `RIGNAME`.** O script pega os 12 primeiros caracteres do hostname e os grava no lugar de `RIGNAME` dentro do `config.json`. "Rig" é o termo de mineração para a máquina que minera, e etiquetar cada uma pelo hostname é prática em configurações de mineradores como o XMRig, para o operador acompanhar cada máquina infectada no painel do pool. É o indício mais forte sobre a finalidade do payload.
6. **Execução em segundo plano.** `setsid sh run.sh >/dev/null 2>&1 &` roda o `run.sh` do pacote desvinculado do terminal (sobrevive ao logout) e descarta toda a saída. Quem está na máquina não vê nada.
7. **Checagem de que "pegou".** Após `sleep 10`, o script procura processos chamados `c` e `x` dentro da pasta `.qc…` (o `[.]qc` é um truque para o `grep` não encontrar a si mesmo). Nomes de uma letra só dificultam identificar esses processos em `ps` e `top`.

8. **Relatório final.** Imprime `LITE_DONE <hostname> dl=… dir=… procs=…`. Esses códigos de status (`NODL`, `NOTAR`, `LITE_DONE`), sempre acompanhados do hostname, foram pensados para uma ferramenta que roda o script em muitas máquinas de uma vez e coleta os resultados. "LITE" sugere uma versão enxuta de um kit maior.

O que esta análise não cobre

Fiz apenas análise estática: não executei o script nem baixei o pacote (o que só se deve fazer em sandbox isolado). Não vi, portanto, o conteúdo de `fleet_lin.tgz`, `run.sh`, `config.json`, `c` e `x`, e a conclusão "minerador" é uma inferência forte, não confirmada. Se o payload for outra coisa (backdoor, bot de DDoS…), o script continua igualmente malicioso. O script também não cria persistência por conta própria, mas o `run.sh` do pacote pode. Por fim, não consultei a reputação do IP. Vale checá-lo, junto com o hash do arquivo, no VirusTotal ou no AbuseIPDB.

Veredito final

É malware. Nenhum comando isolado é suspeito (`curl`, `tar` e `setsid` são ferramentas normais). O que condena é a combinação: download de IP cru sem criptografia nem verificação, pasta oculta, cascata de fallbacks, execução silenciosa em segundo plano, binários de uma letra, o marcador `RIGNAME` e a saída padronizada para controle em escala. É o padrão clássico de cryptojacking e de loaders de botnet. O único cenário "legítimo" seria você ser dono dos servidores e ter autorizado a mineração, o que não combina com esse nível de ocultação.

Indicadores e o que fazer se foi executado

Indicadores para busca e bloqueio:

- `23.252.123.134:18095` e a URL `http://23.252.123.134:18095/fleet_lin.tgz`
- `/tmp/.qc<PID>/` com `f.tgz`, `config.json`, `run.sh` e os executáveis `c` e `x` (ou esses arquivos direto em `/tmp`, caso a pasta oculta falhe)
- Textos de saída `NODL`, `NOTAR` e `LITE_DONE`

Se foi executado em alguma máquina:

- Procure `/tmp/.qc*`, processos rodando de lá (`pgrep -af '/tmp/\.qc'`), CPU alta e contínua e conexões de saída (`ss -tnp`) para o IP acima ou para pools de mineração.
- Verifique persistência: crontabs de todos os usuários, `/etc/cron*`, serviços e timers do systemd, `rc.local`, `.bashrc` e `~/.ssh/authorized_keys`.
- Bloqueie o IP no firewall e encerre os processos.
- Mais importante: este script é só uma etapa. Alguém precisou colocá-lo lá, então descubra o vetor de entrada (SSH com senha fraca, Docker/Redis/Jenkins expostos, aplicação vulnerável…), troque credenciais e chaves e, se possível, reconstrua a máquina a partir de uma imagem limpa.

Se você encontrou o arquivo em algum servidor, me conte o contexto (onde estava e se chegou a ser executado) que eu ajudo a avaliar o impacto e a limpeza.

Qual é a categoria principal deste malware?

Ajustando a classificação do MITRE ATT&CK ▸

A categoria principal do script é **downloader** (também chamado de *loader* ou *stager*). Ele não carrega a carga maliciosa: só baixa o pacote de um servidor remoto, extrai, ajusta a configuração e dispara a execução em segundo plano.

Uma correção de terminologia: na análise anterior usei "dropper" em sentido amplo. Estritamente, um dropper traz o payload embutido, e este script o busca na rede, então "downloader" é o termo mais preciso.

A categoria da ameaça como um todo, ou seja, o que o payload faz, provavelmente é **cryptojacking (coinminer)**, pelo marcador `RIGNAME` e pela etiquetagem de cada máquina pelo hostname. Isso é inferência, porque não vi o conteúdo de `fleet_lin.tgz`. Se o pacote for um backdoor ou um bot de DDoS, a categoria final muda, mas o script continua sendo um downloader malicioso.

No MITRE ATT&CK, o comportamento do script corresponde a T1105 (Ingress Tool Transfer), T1059.004 (Unix Shell) e T1564.001 (Hidden Files and Directories), com T1496 (Resource Hijacking) se o payload for mesmo um minerador.